

大数据安全考试合集

填空题

1. (P6) 大数据安全包含 大数据服务中的安全问题 和 大数据技术在安全领域的应用 两重含义。
2. (P6) 大数据技术在安全领域的应用，主要包括以下两个方面的内容：利用大数据技术解决安全问题 和 攻击者基于大数据技术开发新的攻击技术。
3. (P9) 2021 年，我国颁布实施了两部数据安全方面的基础性法律：《中华人民共和国个人信息保护法》 和 《中华人民共和国数据安全法》。
4. (P34) 密码学的攻击模型可以分为 黑盒攻击、灰盒攻击 和 白盒攻击。
5. (P37) 一次一密系统是否满足 NM（不可塑性，Non-malleability）的安全目标？不满足。
6. (P49) TLS 协议可分为 TLS 握手协议（负责密码组件的协商以及安全信道的建立）和 TLS 记录协议（在已建立的安全信道中传输秘密信息）。
7. (P96) 在 FIDO UAF 协议中，用户通过位于设备本地的认证器完成 身份识别 并产生公私钥对，认证器使用私钥签名，服务端使用 公钥 进行验证，完成身份认证。
8. (P107) 在 Kerberos 协议中有两种票据，票据许可票据 用于用户访问票据授权服务器，服务票据 用于用户访问应用服务器。
9. (P110) 开放认证授权 (OAuth) 协议的四种模式：授权码模式、简化模式、密码模式 和 客户端模式。
10. (P131) 容器技术的三个核心概念：镜像、容器 和 仓库。
11. (P136) 常见的容器安全问题有 容器逃逸问题、镜像安全问题、集群入侵。
12. (P136) 产生容器逃逸的主要原因有两类：软件漏洞 和 错误的配置。
13. (P174) 安全多方计算模型可以分为 半诚实模型 和 恶意模型。
14. (P174) 安全多方计算模型中的参与者可以分为三类：诚实参与者、半诚实参与者 和 恶意参与者。
15. (P175) 在无限计算能力的攻击者模型下的安全的多方计算协议为 基于信息论安全 的多方计算协议；在有限计算能力的攻击者模型下的安全的多方计算

协议为 基于密码学安全 的多方计算协议。

16. (P233) 发布-遗忘模型中数据匿名化的主要步骤包括：识别身份信息、抑制、泛化 和 聚合。

17. (P241) 差分隐私的通用随机算法有 拉普拉斯机制、指数机制 和 高斯机制。

18. (P310) 匿名属性包括 不可辨识性 和 不可联系性。

19. (PPT-CH2-38) 密钥封装机制 (Key Encapsulation Mechanism, KEM) 是指 用非对称加密算法加密对称密钥；数据封装机制 (Data Encapsulation Mechanism, DEM) 是指 用对称密钥算法加密消息。

20. (PPT-CH2-73) 一个加密算法的明文和密文一样长，请问：该加密算法是语义安全的吗？否。

21. (课后习题) 数据 是数字经济时代核心的生产要素。

22. (课后习题) 隐私保护不仅要保护用户数据的机密性，还要保护用户行为数据的 不可区分性，也就是对用户元数据的保护。

23. 访问控制技术是信息系统安全的核心技术之一，该技术中 主体 是请求访问的实体，客体 是接受访问的实体，控制策略 是主体对客体的访问规则集。

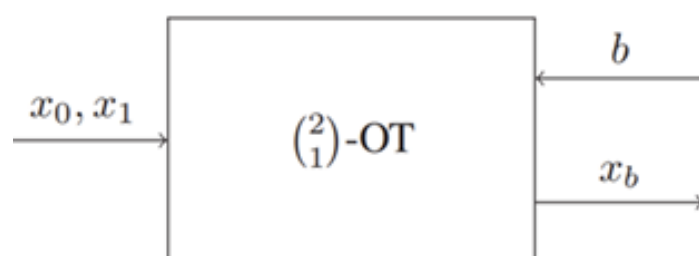
24. 如果 x' 是通过从 x 删除一行来构造的，则 $d(x, x') = \underline{1}$ 。

25. 如果 x' 是通过从 x 修改一行来构造的，则 $d(x, x') = \underline{2}$ 。

26. 消息锁定加密是语义安全的吗？否。

27. 收敛加密是语义安全的吗？否。

28. 在下图的 2 选 1 不经意传输(OT)模型中，当 $b=0$ 时， $x_b = \underline{x_0}$ 。



选择题

1. 下述哪些安全概念等价于语义安全？（P37）（D）
A. NM-CPA B. IND-CCA C. PRV\$-CDA D. IND-CPA（语义安全）
2. 下述哪些陈述是正确的？（P37）（BCD）
A. AES 加密算法是语义安全的
B. RSA-OAEP 加密算法是语义安全的
C. AES-CTR 加密方案是语义安全的
D. 椭圆曲线加密算法是语义安全的
3. 下述哪些陈述是正确的？（P37）（ACD）
A. AES-CBC 加密方案是语义安全的
B. RSA 加密算法是语义安全的
C. AES-GCM 加密方案是语义安全的
D. ElGamal 加密算法是语义安全的
4. TLS 握手协议的任务包括：（P49）（ABC）
A. 协商密钥规格
B. 利用公钥证书来认证服务器的身份
C. 生成会话密钥
D. 用会话密钥加密传输的数据
5. 以下哪些技术是用来解决仿冒证书问题的？（P68）（A）
A. CT（certificate transparency） B. HTTP Public Key Pinning（HPKP）
C. CDN D. 自动证书管理环境(ACME)协议
6. 由于计算机的普及，很多攻击者具有更强大的计算能力。1979 年，Robert Morris 和 Ken Thompson 提出了哈希加盐（Hashing and Salting）的方法来对口令进行加密处理，来抵抗字典攻击和暴力破解，并应用于 Unix 操作系统。以下哪些方法比哈希加盐的方法更安全？（P90）（ABCD）
A. PBKDF2(Password-Based Key Derivation Function) B. BCrypt
C. SCRYPT D. Argon2
7. 以下关于 FIDO 协议的论述哪些是正确的？（P96）（ABC）
A. FIDO 协议的在线身份认证采用了非对称公钥密码技术来提供安全保障

- B. FIDO 协议包括本地身份识别与在线身份认证两部分
- C. FIDO 协议支持指纹、语音、虹膜、脸部识别等生物身份识别方式
- D. FIDO 协议的在线身份认证采用了对称密码技术来提供安全保障
8. 容器与虚拟机相比较的优势有? (P133) (ABC)
- A. 占用存储空间小, 下载传输快 B. 消耗的 CPU 和内存更少
- C. 启动速度更快 D. 更安全
9. 容器与虚拟机相比较, 下述哪些陈述是正确的? (P133) (ABCD)
- A. 容器占用存储空间小, 下载传输快 B. 容器消耗的 CPU 和内存更少
- C. 容器启动速度更快 D. 容器安全性比虚拟机低
10. Paillier 加密算法是? (P164) (BC)
- A. 对称密码算法 B. 公钥密码算法 C. 加法同态加密算法 D. 乘法同态加密算法
11. 实现数据匿名化的主要方法有? (P234) (ABC)
- A. 泛化 B. 抑制 C. 聚合 D. 过滤
12. 静态数据发布原则 L-diversity 保证发布数据集的披露风险小于?
- (P238? ? ?) (A)
- A. $1/L$ B. $2/L$ C. $1/(2L)$ D. $1/(3L)$
13. 遵循 K 匿名模型发布数据, 数据集的披露风险小于? (P236? ? ?) (A)
- A. $1/K$ B. $2/K$ C. $1/(2K)$ D. $1/(3K)$
14. 发起者需要在发起匿名通信之前确定整个通信的传输路径的是? (ABD)
- (P311)
- A. 基于 Mix 算法的匿名通信 B. 基于洋葱路由算法的匿名通信
- C. 基于泛洪算法的匿名通信 D. Tor 匿名通信
15. 以下 HTTPS 的部署模式中, 哪个是最安全的? (第三章习题) (D)
- A. HTTP 和 HTTPS 并存 B. HTTP 默认跳转到 HTTPS
- C. 持久跳转 HTTPS(HSTS) D. HSTS + HSTS Preload

综合题

(2324A) (2425A)简答题（8分）（P36）

（1）什么是不可区分性？（2分）

（2）什么是不可塑性？（2分）

（3）攻击模型(例如，CPA 和 CCA)与安全目标(例如，NM 和 IND)相结合，可以构建安全概念 NM-CPA，NM-CCA，IND-CPA 和 IND-CCA。请解释一下四个安全概念之间的关系。（4分）

（1）不可区分性（IND）是指对手无法从密文中获得关于相应明文的任何信息。密文应该与随机字符串没有区别。

（2）不可塑性（NM）是指对手在获得挑战密文访问权限后，无法生成与挑战密文有意义相关的不同密文。

（3）IND-CCA 蕴含着 IND-CPA，而 NM-CCA 蕴含着 NM-CPA，因为 CPA 攻击者可以做的事情，CCA 攻击者也可以做。**也就是说，如果无法通过执行选择的密文和选择的明文查询来攻破密码，那么您就不能仅通过执行选择的明文查询来攻破密码。一个不太明显的关系是，IND-CPA 并不蕴含 NM-CPA。但是相反的关系确实成立：NM-CPA 蕴含 IND-CPA。IND-CCA 和 NM-CCA 是等同的概念，它们各自蕴含彼此。

(2324B) (2425B)简答题：TLS 协议的安全性（5分）（P53）

（1）TLS 协议如何防止传输的消息被窃听和篡改？（2分）

（2）TLS 协议如何防止中间人攻击？（1分）

（3）TLS 协议如何防止消息重放攻击？（1分）

（4）TLS 协议如何提供前向安全性的？（1分）

（1）TLS 通过加密传输数据防止窃听，通过消息认证码（MAC）或认证加密（AEAD）防止篡改，并利用数字证书验证通信方身份，确保端到端安全。

（2）中间人攻击：DHE 无法抵御中间人攻击。攻击者只需要冒充连接双方并执行两次单独的密钥交换即可实现攻击。解决方法是服务器发送服务器端 DH 参数时，需要对服务器端 DH 参数进行数字签名，证明服务器的身份。

（3）重放攻击：在握手时使用 Client Random 和 Server Random，防止连接重

放。

(4) 前向安全性：可以采用 DHE 密钥交换协议，支持前向安全性，目前大部分 HTTPS 流量用的都是 ECDHE 密钥交换

(2324B) (2425B)简答题（5 分）（P61）

(1) 简述 HTTP Strict Transport Security (通常简称为 HSTS)的概念

(2) 解释 HSTS Preload List 的作用与工作原理

(3) 描述 HSTS 响应头格式

(1) HSTS 是国际互联网工程组织 IETF 发布的一种互联网安全策略机制。采用 HSTS 策略的网站将保证浏览器始终连接到该网站的 HTTPS 加密版本，不需要用户手动在 URL 地址栏中输入加密地址，以减少会话劫持风险。

(2) 作用：让浏览器在首次访问网站时也强制使用 HTTPS，避免第一次连接被劫持。原理：网站管理员向浏览器厂商提交域名，浏览器内置一份“预加载列表”，用户访问该域名时直接走 HTTPS。

(3) HSTS 响应头格式如下：Strict-Transport-Security: max-age=<seconds>; [includeSubDomains;] [preload]。max-age 指定浏览器在多少秒内强制使用 HTTPS 访问该域名（单位：秒）。includeSubDomains：该策略适用于所有子域名。preload：表明该域名希望加入浏览器的 HSTS 预加载列表，以实现首次访问即强制 HTTPS（需手动提交到预加载列表）。

(2425A)估算用户秘密的熵值（4 分）（P86）

(1) 有一款加密货币钱包，其助记词词典包含 2048 个单词，生成密语种子时用户选择的助记词由助记词词典中的 12 个英文单词组成。分析一下该加密货币钱包助记词的熵值。（2 分）

(2) 某应用系统的口令设置，要求用户口令必须包含数字、大小写字母、特殊字符，口令长度不少于 10 个字符。分析一下该应用系统用户口令的安全性。（2 分）

(1) 助记词熵值分析：助记词从 2048 个单词的词典中选取 12 个，且通常顺序相关（即每个位置独立选词）。每个单词的熵为： $\log_2(2048) = 11$ 比特。12

个单词的总熵为：12 x 11 = 132 比特

(2) 用户口令安全性分析

要求：长度 ≥ 10 个字符，且包含数字、大小写字母、特殊字符。

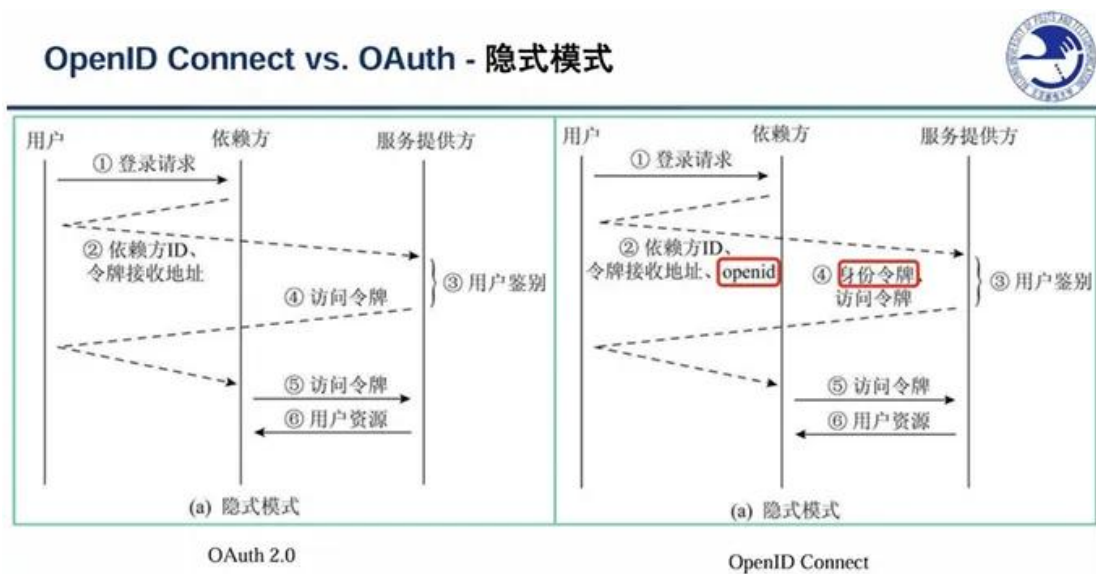
假设字符集大小：大写字母 (26) + 小写字母 (26) + 数字 (10) + 特殊字符 (假设至少 10 个，如 !@#\$%^&*()), 合计约 72 个字符。

理论上 10 位随机口令的熵为： $\log_2(72^{10}) = 61.7$ 比特

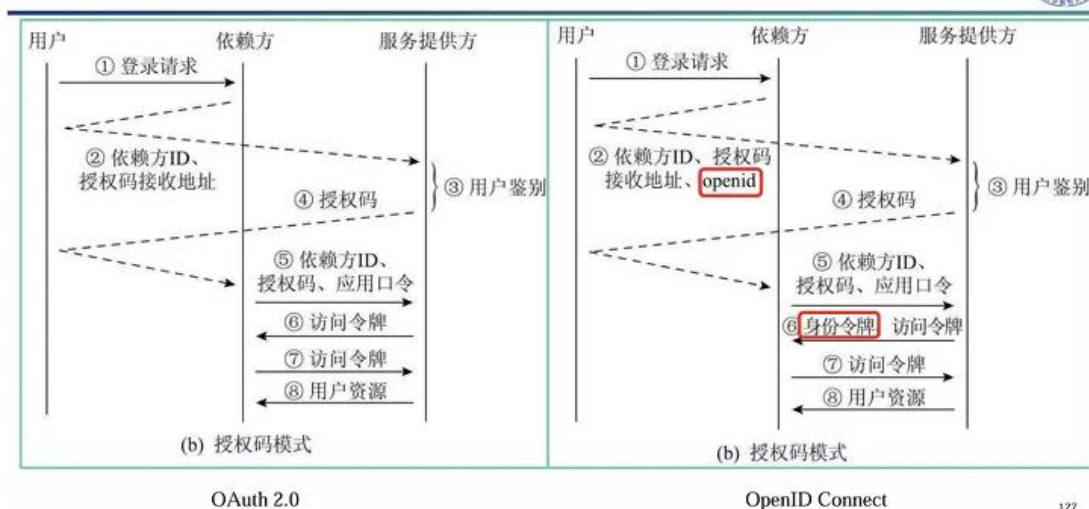
但在现实中，用户倾向于用可预测的模式组合（如 Aa123456!@），实际熵远低于理论值。

常见攻击风险：用户常用键盘规律、单词变形、常见替换（如 @代替 a），使得口令易受字典和规则攻击。若系统无其他保护（如速率限制、锁定机制），短口令（10 位）仍可能被离线破解（若哈希函数强度不足）。

(2324A)解释一下 OpenID Connect 协议与 OAuth 协议的关系与区别，以授权码模式和隐式模式为例画图说明。（5 分）(P113)



OpenID Connect vs. OAuth -授权码模式



127

OpenID Connect 协议与 OAuth 2.0 协议流程基本相同，主要区别是身份鉴别请求中添加 openid 参数，身份服务提供方（IdP）最终会发送给依赖方一个 JWT 格式的身份令牌而不是访问令牌。访问令牌主要区别在于：访问令牌只是一个随机字符串，而身份令牌则携带了依赖方、服务提供方、用户等信息并进行了签名。相较于 OAuth2.0 协议更适合用于用户身份鉴别

(2223B) (2425B)数据可恢复性证明 POR 机制的基本思路（10 分）

(2324B)简要解释 POR 机制的基本工作原理（5 分）（P156）

POR 的验证机制需要解决以下两个问题：更有效地识别外包文件中出现的损坏。能恢复已损坏的数据文件。基本的思路是通过增加验证信息来提高验证的效率，并运用纠错编码技术来恢复被损坏的数据。

针对第一个问题，可以在外包的文件中预先植入一些称之为岗哨位的检验数据块，并在本地存储好这些检验数据块。对于远程服务器而言，这些岗哨数据块与数据块是无法区分的；倘若服务器损坏了数据文件中部分内容，也会相应地损坏到岗哨文件块。对比存储在本地的检验数据，能判断远程节点上的数据是否是完整的。另外通过岗哨块损坏的数目，可以评估文件中出错的部分在整个文件中所占的比例。针对第二个问题，通常利用 RS 纠错码对文件进行容错预处理，使用纠错机制可以恢复一部分损坏的数据。

(2122A) (2324A) 阐述加密数据去重的基本原理 (10 分) (P157)

加密数据去重旨在对密文进行去重，以节省存储空间，同时保护数据隐私。其核心矛盾在于：传统加密（如 AES-CTR）使用随机性或不同密钥，使相同明文加密为不同密文，无法去重。若允许相同明文加密为相同密文，则会泄露“明文相等性”，带来安全风险。因此，加密数据去重的基本原理是在安全性与去重效率之间权衡，采用允许确定性加密但限制信息泄露的方案，主要有以下两类方法。

方案一：收敛加密 (CE)：数据块 d 的加密为 $E(\text{hash}(d), d)$ ，其中第一个参数为密钥 key ，方法选用一个对称加密算法如 AES。可以认为， $h(x)$ 输出的一部分作为 key ，另外一部分作为算法所需的随机数如 IV。这样，同样的数据块一定会被加密成同样的密文，后续可以做去重。

方案二：消息锁定加密 (MLE)，它使用的 key 是从待加密的原文算出来的。CE 是 MLE 的一种特例，CE 和 MLE 满足 PRV\$-CDA，比其他相关的安全性都更强。

(以下是课后习题的答案) 目标：在云存储中既能保证隐私，又能实现数据去重（节省存储）。基本原理：最早提出的方案是 CE：当需要加密一个数据块 d 的时候，CE 先用数据内容生成密钥，再用一个对称加密算法加密。

(2223B) (2324B) (2425B) 同态加密 (10 分) (P163)

(1) 请给出同态加密的定义

(2) 证明：RSA 算法是乘法同态的

(3) 证明：Paillier 算法是加法同态的

(1) 记加密操作为 E ，明文为 m ，加密得 c ，即 $c=E(m)$ ， $m=D(c)$ 。已知针对明文有操作 f ，针对 E 可构造 F ，使得 $F(c)=E(f(m))$ ，这样 E 就是一个针对 f 的同态加密算法。假设 f 是个很复杂的操作，有了同态加密，我们就可以把加密得到的 c 交给第三方，第三方进行操作 F ，我们拿回 $F(c)$ 后，一解密，就得到了 $f(m)$ 。第三方替我们干了活，对 m 却仍一无所知，多么融洽的关系啊。

(2) RSA 加密： $E(m) = m^e \bmod N$ 。

两密文乘积： $E(m_1)E(m_2) = m_1^e m_2^e = (m_1 m_2)^e \bmod N$ 。

解密得 $(m_1 m_2)^{ed} \equiv m_1 m_2 \pmod{N}$ 。→ RSA 对乘法同态。

(3) Paillier 加密: $E(m) = g^m r^N \pmod{N^2}$ 。

乘积: $E(m_1)E(m_2) = g^{m_1} r_1^N \cdot g^{m_2} r_2^N = g^{m_1+m_2} (r_1 r_2)^N \pmod{N^2}$ 。

该乘积即为对明文 $m_1 + m_2$ 的合法加密, 解密得到 $m_1 + m_2 \pmod{N}$ → Paillier 对加法同态。

(2425A) Paillier 密码算法: 对于同一个明文 m , 为什么每次加密出来的密文不同却都能够正确解密出明文 m ? 请予以证明。(3 分)(P164)

同一明文每次加密不同但能正确解密的证明:

加密: 选随机 $r \in \mathbb{Z}_N^*$, 计算 $c = g^m r^N \pmod{N^2}$ 。不同 $r \rightarrow$ 不同 c 。

解密 (关键步): 计算 $c^\lambda \pmod{N^2} = (g^m r^N)^\lambda \equiv g^{m\lambda} \pmod{N^2}$ (因为 $(r^N)^\lambda \equiv 1$), 用函数 $L(u) = (u - 1)/N$ 得到与 m 线性相关的值, 除以常数 $L(g^\lambda)$ 得到 m 。因此随机 r 只改变掩盖项 r^N , 不影响通过 c^λ 提取明文的过程, 解密仍返回原 m 。

(2122A) (2324A) (2425A) 安全多方计算问题 (15 分)(P173)

(1) 请阐述姚期智提出的百万富翁问题的解决方案, 并对其正确性和安全性进行分析。(9 分)

(2) 设计一个基于 OT 协议的百万富翁问题解决方案, 并给出一个该 OT 协议的具体实现方案 (如果能够给出课堂上没有讲过的 OT 协议实现方案, 本题目可以获得额外加分)。(6 分)

• 解决方案

1982 年, 姚期智教授提出的百万富翁协议是解决百万富翁问题的最早方案。在该协议中, 假设 Alice 的秘密输入为 a , Bob 的秘密输入为 b , 满足 $1 \leq a < b \leq n$ (原协议的要求是 $1 \leq a < b \leq 10$, 为了保证通用性, 这里假设 $1 \leq a < b \leq n$, n 是大于 1 的某个正整数)。令 M 是所有 N bit 非负整数的集合, Q_N 是所有从 M 到 M 的一一映射函数的集合。令 E_A 是 Alice 的公钥, 它是从 Q_N 中随机抽取的。该协议的具体描述如下。

输入: Alice 有一个秘密输入 a , Bob 有一个秘密输入 b 。

输出: Alice 和 Bob 得到 a 和 b 的大小关系。

① Bob 随机选取一个 N bit 的整数 x , 秘密计算 $E_A(x)$ 的值, 并把该值记为 k 。

② Bob 将 $k-b+1$ 发送给 Alice。

③ Alice 秘密地计算 $y_u = D_A(k-b+u)$ 的值 ($u=1, 2, \dots, n$)。

④ Alice 产生一个 $N/2$ bit 的随机素数 p , 对所有 u 计算 $z_u = y_u \pmod p$ 。如果所有的 z_u 在模 p 运算下至少相差 2, 则停止。否则, 重新产生一个随机素数 p 重复上面的步骤, 直到所有的 z_u 至少相差 2。用 $p, z_u (u=1, 2, \dots, n)$ 表示最终产生的这些数。

⑤ Alice 将素数 p 以及下面的 n 个数都发送给 Bob (下列数都在模 p 运算下):

$$z_1, z_2, \dots, z_a, z_{a+1}+1, \dots, z_n+1$$

⑥ Bob 检验由 Alice 传送过来的不包括 p 在内的第 b 个值, 若它等于 $x \pmod p$, 则 $a \geq b$, 否则 $a < b$ 。

⑦ Bob 把结论告诉 Alice。

正确性分析

$$z_1, z_2, \dots, z_a, z_{a+1}+1, \dots, z_n+1$$

上述协议能正确判断出 a 和 b 的大小关系, 因为

$$z_u = D_A[E_A(x) - b + u] \pmod p$$

特别地, 有

$$z_b = D_A[E_A(x) - b + b] \pmod p = D_A[E_A(x)] \pmod p = x \pmod p$$

如果 $a \geq b$, 那么第 b 个值为 $z_b = x \pmod p$, 否则为 $z_b + 1 = (x \pmod p) + 1 \neq (x \pmod p)$ 。所以, Bob 通过检验由 Alice 传送的不包括 p 在内的第 b 个值, 可以判断 a 和 b 的大小。

但是, 协议仍然存在一些可以被攻击的地方。例如, Bob 有可能选择随机数 t , 并验证 $E_A(t) = k - b + n - 1$ 是否成立。如果他尝试成功了, 他便知道 $y_{n-1} = t$, 从而他也得知了 z_{n-1} 的值。因此他能够得知 a 是否大于等于 $n-1$ 。而且, 在协议的最后一步, Bob 可能欺骗 Alice, 告诉 Alice 一个错误的结论。所以, 该协议不能对抗主动攻击, 即不能使用在恶意模型下。

另外, 该协议的复杂度是指数级的, 效率非常低, 不实用。但是, 该协议的设计思想是简单的, 实际上它主要将 a 在一个有序数中的位置做了隐藏的“标记”, 在 a 之前的数使用一种标记, 在 a 之后的数使用另外一种标记, 然后让 b 揭示它所在位置的“标记”, 如果是前一种, 则 b 比 a 小, 否则 b 比 a 大。由于简单的设计原理, 该协议成为百万富翁协议中较为经典的一个。

(2) 基于 OT 的百万富翁问题解决方案 (6 分)

1) 基于 OT 的整体思路 (不使用完整混淆电路)

- 设 a, b 为 k 位二进制数
- 从最高位到最低位逐位比较
- 在第 i 位:
 - 若高位已经分出大小则停止
 - 否则比较 a_i 与 b_i
- 核心目标:

Bob 在不知道 a_i 的情况下, 获得“该位是否决定胜负”的信息

典型做法:

- Alice 为每一位 i 构造两个消息:

$$m_i^0 = \text{当 } b_i = 0 \text{ 时的比较结果}, \quad m_i^1 = \text{当 } b_i = 1 \text{ 时的比较结果}$$

- Bob 通过 1-out-of-2 OT 只得到 $m_i^{b_i}$
- 逐位更新比较状态, 最终得到 $a > b$

2) 一个具体的 1-out-of-2 OT 实现方案 (基于 Diffie-Hellman)

这是课堂常见、写出来最稳的一种 OT 实现

OT 目标

- Alice 输入: (m_0, m_1)
- Bob 输入: 选择位 $c \in \{0, 1\}$
- Bob 得到 m_c , Alice 不知道 c

协议步骤 (简版)

1. 系统参数

- 选大素数 p , 生成元 g , 工作在 $\mathbb{Z}_p^*$

2. Bob 选择

- 随机选 x , 计算 $h = g^x$
- 若 $c = 0$: 发送 (h, g)
- 若 $c = 1$: 发送 (g, h)

3. Alice 加密

- 对收到的两个元素 (h_0, h_1)
- 随机选 r_0, r_1
- 计算

$$k_0 = h_0^{r_0}, \quad k_1 = h_1^{r_1}$$

- 发送

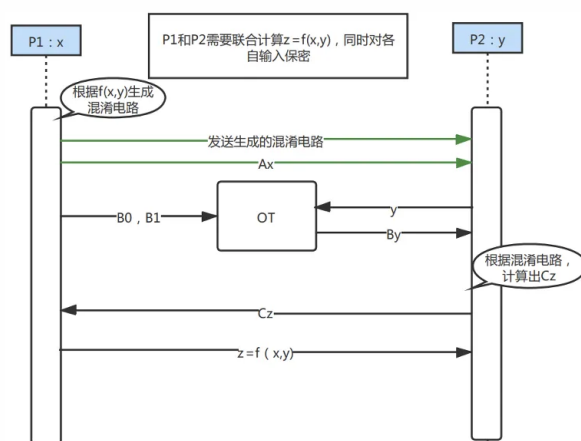
$$(g^{r_0}, Enc_{k_0}(m_0)), \quad (g^{r_1}, Enc_{k_1}(m_1))$$

4. Bob 解密

- 仅对自己知道离散对数的那一项可算出密钥 k_c
- 解密得到 m_c , 另一条无法解密

(2122A) (2324A) (2425A) 解释一下姚氏混淆电路的工作原理。(10 分) (P175)

姚氏混淆电路是一种安全多方计算 (MPC) 协议, 允许两方在不泄露各自输入的情况下, 共同计算一个函数。其核心思想是将要计算的函数表示为一个布尔电路, 然后通过对电路进行“混淆”来实现隐私保护。



步骤一：电路产生阶段。参与运算的双方先就需要安全计算的目的依靠专有编程语言(DSL)或相关编程语言扩展等进行编程，然后针对实现计算的程序进行编译，生成布尔电路文件;然后针对双方输入值以及中间输出结果随机产生映射 label,再利用这些 label 做为 key 对每个对应的电路输出真值表采用分组密码方式进行加密，并对真值表值进行打乱操作，这一步就是混淆电路的概念。

步骤二：电路执行阶段。电路执行者针对布尔电路文件进行执行，执行时电路生成者需要将自己的输入所对应的 label 发给电路执行者；电路执行者依据自己所有信息通过 OT 方式选择自己对应的 label，这样电路生成者与执行者均不到对方的输入数据；电路执行者此时获取双方输入对应的 label,作为 key 的相关信息对真值表进行解密，即可获取真值表的内容，循环往复，直至所有电路执行完毕，输出执行结果。

(2122A) (2223B) (2324A) (2324B)隐私的定义、分类、及其度量与量化表示（10分）（P227）

（1）定义：隐私就是个人、机构等实体不愿意被外部世界知晓的敏感信息。在具体应用中，隐私即为数据所有者不愿意被披露的敏感信息，包括敏感数据以及数据所表征的特性。如个人的薪资、病人的患病记录、公司的财务信息等。

（2）分类：

①个人隐私：任何可以确认特定个人或与可确认的个人相关、但个人不愿被暴露的信息，都叫做个人隐私，如身份证号、就诊记录等。

②共同隐私：共同隐私不仅包含个人的隐私，还包含所有个人共同表现出但不愿被暴露的信息。如公司员工的平均薪资、薪资分布等信息，再如两个人之间的关系信息。

（3）度量和量化表示：隐私度量可以统一用“披露风险”来描述。披露风险表示攻击者根据所发布的数据和其它背景知识，可能披露隐私的概率。若 s 表示敏感数据，事件 S_k 表示“攻击者在背景知识 K 的帮助下揭露敏感数据 s ”，则披露风险 $r(S,K)$ 表示为 $r(S,K)=Pr(S_k)$ 。对数据集而言，若数据所有者最终发布数据集 D 的所有敏感数据的披露风险都小于阈值 α ， $\alpha \in [0,1]$ ，则称该数据集的披露风险为 α 。

(2122A)阐述 SSL 握手协议的主要流程，然后分析一下 SSL 握手协议中 RSA 密钥交换的安全性，并提出改进方案。(10 分)(???)

(1) SSL 握手协议主要流程：交换 Hello 消息，对于算法、交换随机值等协商一致；交换必要的密码参数，以便双方得到统一的预主密钥；交换证书和相应的密码信息，以便进行身份认证；产生主密钥；把安全参数提供给 TLS 记录层；检验双方是否已经获得同样的安全参数。

(2) RSA 密钥交换的安全性分析：

优点：证书绑定服务器身份，防止中间人攻击（需 CA 可信）。加密的预备主密钥只有服务器能解密，实现了密钥保密。

安全缺陷：不具备前向安全性。如果服务器私钥泄露，过去的通信可被解密。重放攻击风险。虽然 TLS 有随机数和时间戳，但 RSA 密钥交换本身不防范握手重放，需依赖 Nonce 和会话标识。密钥交换确定性问题。预备主密钥由客户端单方生成，如果客户端随机数质量差，会影响安全性。

(3) 改进方案：使用 DHE 密钥交换。将 RSA 仅用于身份验证，密钥交换采用 (EC) Diffie-Hellman 临时模式，实现前向安全。采用更新的 TLS 版本。升级到 TLS 1.3，其中 RSA 密钥交换被废弃，只支持前向安全的密钥交换。强化证书验证机制：结合 OCSP Stapling 和 Certificate Transparency 防止假冒证书攻击，提升身份验证安全性。使用基于 PQC 的混合密钥交换。为应对量子计算威胁，采用混合方案，如 TLS 结合 ECDHE 与后量子密钥封装 (Kyber) 等。

(2122A) (2223B) (2324A) (2324B)简述 K 匿名、L 多样性、T 相近隐私保护模型的基本思想及其存在的问题 (10 分) (P236)

(1) K 匿名隐私保护模型的思想：采用泛化和抑制技术对原始数据进行匿名化处理以便得到满足 k-匿名规则的匿名数据，从而使得攻击者不能根据发布的匿名数据准确的识别出目标个体的记录。K 匿名能抵御记录链接式攻击，但仍存在属性链接攻击！指的是，如果一些敏感值在群组中占了主导地位的话，即使满足 K 匿名，一个成功的推断也会变得相对容易，比如一整个群组都是“艾滋病”，那便很好推断了。

(2) L 多样性要求，每个 qid 组至少包含 L 个有“较好代表性”的敏感值。“较好

代表性”指，每个 qid 组中的敏感属性都有 L 个不同的值。当遭受属性链接攻击时，攻击者也许不能精确地识别目标受害者的记录，但可能从被公布的数据中基于与受害者所属的团体相联系的一系列敏感值集合推理出他的敏感值。

(3) T 相近隐私保护模型：模型需 QID 上任一群组中的敏感值的分布接近于整体表中的属性分布。这些隐私保护模型共同的问题是：陷入了一个“新隐私保护模型不断被提出，但又不断被攻破”的循环中！根本原因是，这些模型基于很多攻击者的假设，但是实际情况中，假定并不完全成立！那转换思路——差分隐私！

(2425B)简答题（10 分）(P236)

(1) 概念解释：K 匿名与记录链接攻击（4 分）

(2) 概念解释：L 多样化与属性链接攻击（4 分）

(3) 数据匿名化方法的局限性（2 分）

(1) K 匿名隐私保护模型：采用泛化和抑制技术对原始数据进行匿名化处理以便得到满足 k-匿名规则的匿名数据，从而使得攻击者不能根据发布的匿名数据准确的识别出目标个体的记录。**记录链接攻击：**例如攻击者知道他的老板在住院，因此，他就知道他的老板的医疗记录将会出现在医院泄露出的患者数据库中。并且，对于这个攻击者来说，得到他老板的出生日期和性别也不是难事，而这些就可以作为相关攻击时的准标识符。攻击者知道 Frank 是一个 38 岁的男律师，并且这个数据集中包含 Frank 的数据，就能够推断出 Frank 的疾病是艾滋病。这种攻击方式被称为记录链接式攻击。

(2) L 多样性要求：每个 qid 组至少包含 L 个有“较好代表性”的敏感值。“较好代表性”指，每个 qid 组中的敏感属性都有 L 个不同的值。**属性链接攻击：**通过观察我们很容易发现一个新的问题：如果攻击者知道 Lily 是一名 30 岁的女性舞蹈演员，并且该数据集中包含 Lily 的数据，从公开的数据集中能够推断出 Lily 的疾病是艾滋病。这种攻击方式被称为属性链接攻击。

(3) 局限性：难以抵御再识别攻击，即使删除显式标识符，攻击者仍可通过准标识符结合外部数据重新识别个体（如斯威尼攻击）；依赖对攻击者背景知识的简化假设，而实际攻击能力往往超出模型假设，导致隐私保护失效；隐私保护

与数据可用性难以平衡，泛化、抑制等手段在增强隐私的同时会显著降低数据精度与实用价值；存在“军备竞赛”，新模型（如 K-匿名→L-多样性→T-相近）不断被新攻击方法突破，难以提供长期稳定的隐私保障。

简答题（5分）（课件）

（1）如何计算两个数据集之间的距离？如何定义临近数据集？（2分）

（2）如果 x' 是通过向 x 添加一行来构造的， x' 与 x 是相邻的吗？为什么？（1分）

（3）在差分隐私中，对于任意两个临近数据集 x 和 x' 和查询函数 f ，如何计算敏感度（1分）

（4）计数问询的敏感度的是多少？（1分）

（1）两个数据集之间的距离通常用它们之间记录的差异数量来衡量。最常见的是用汉明距离，即一个数据集要经过多少次记录的“增、删、改”才能变成另一个数据集。**临近数据集**：如果两个数据集 x 和 x' 的汉明距离为 1（即只相差一条记录），则称它们为临近数据集（相邻数据集）。

（2）是的，它们是相邻的。因为从 x 到 x' 只相差一条记录（即增加一行），汉明距离为 1，符合差分隐私中临近数据集的定义（通常定义为“最多相差一条记录”）。

（3）

对于一个查询函数 $f: \text{数据集} \rightarrow \mathbb{R}^k$ ，其**敏感度**定义为：

$$\Delta f = \max_{x, x' \text{ 相邻}} \|f(x) - f(x')\|_1$$

即，在所有相邻数据集对上，函数 f 输出的**L1 范数**的最大变化量。

如果 f 输出是实数 ($k = 1$)，则敏感度简化为：

$$\Delta f = \max_{x, x' \text{ 相邻}} |f(x) - f(x')|$$

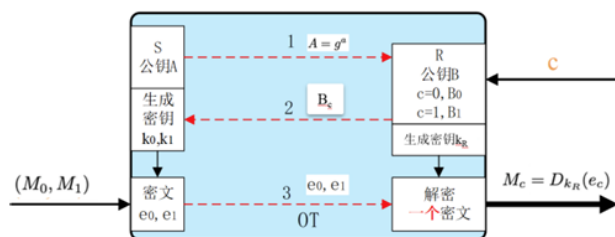
敏感度刻画了**单个个体记录**对查询结果的最大可能影响，是差分隐私机制中添加噪声量的重要参数。

（4）计数问询（数据库 SQL 中的 COUNT 算子）计算数据集中满足特定属性的行数。一般来说，计数问询的敏感度总等于 1。这是因为向数据集中添加一行数据最多会使问询的输出结果增加 1，即当新增行满足特定属性时，计数结果加 1。

简述工作原理

(P177)

6. 参考下图，解释一下 1-out-of-2 OT 协议的工作原理。(10 分)



Algorithm 1 基础 2 选 1OT 协议

发送方 S 输入: (M_0, M_1)

接收方 R 输入: 选择向量 c

共同输入: 素数 p , 生成元 $g \in Z_p$, 哈希函数 H

1: $S \rightarrow R, a \leftarrow Z_p$

• 将 $A = g^a$ 发送给 R , 由于离散对数难题, R 无法破译 a

2: $R \rightarrow S, b \leftarrow Z_p$

• 如果 $c = 0, B = g^b$; 如果 $c = 1, B = Ag^b$, 将 B 发送给 S

• 计算 $k_R = H(A^b)$

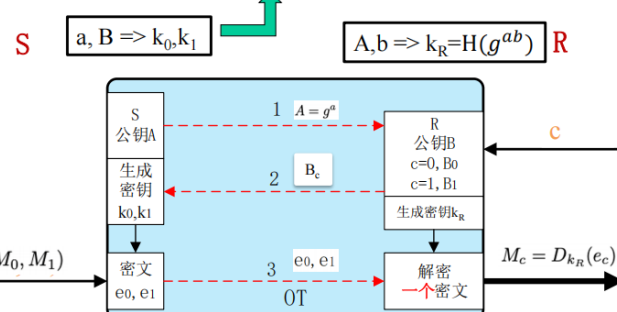
3: S 计算密钥, 并加密消息, 发送给 R :

• $k_0 = H(B^a), e_0 \leftarrow E_{k_0}(M_0)$

• $k_1 = H\left(\left(\frac{B}{A}\right)^a\right), e_1 \leftarrow E_{k_1}(M_1)$

4: R 解密获得 $M_c = D_{k_R}(e_c)$

	K_0	K_1
$c=0$	$B_0 = g^b$ $H(B^a) = H(g^{ab})$	$H\left(\left(\frac{B}{A}\right)^a\right) = H(g^{(b-a)a}) = H(g^{ab-a^2})$
$c=1$	$B_1 = Ag^b = g^{a+b}$ $H(B^a) = H(g^{(a+b)a})$	$H\left(\left(\frac{B}{A}\right)^a\right) = H((g^b)^a) = H(g^{ab})$



$$k_R = H(A^b) = H(g^{ab})$$

如果 $c = 0, k_0 = H(g^{ab}), k_1 = H(g^{ab-a^2})$

如果 $c = 1, k_0 = H(g^{(a+b)a}), k_1 = H(g^{ab})$

由于离散对数难题, R 只能获得选择向量对应密钥, 并解密获得 M_c 。

阐述差分隐私的工作原理 (10 分)



(1) 直接发布查询结果是不安全的: 如果用户直接向数据库发起查询, 数据发布者若返回精确的查询结果, 攻击者可能通过多次查询或结合背景知识, 反推出数据库中某个个体的敏感信息, 从而导致隐私泄露。

(2) 引入中间件: 为避免上述风险, 差分隐私系统并不直接对数据库结果进行

发布，而是先从数据库中提炼出一个中间件。

(3) 随机算法注入噪声：系统对中间件应用精心设计的随机算法，向中间件中注入适量随机噪声，生成一个带噪中间件。

(4) 生成并发布带噪查询结果：再由带噪中间件推导出带噪的查询结果，将该结果返回给用户。

(5) 隐私保护效果：这样，即使攻击者能够从带噪的结果反推得到带噪中间件，他也不可能准确推断出无噪中间件，更不可能对原数据库进行推理，从而达到了保护隐私的目的。

(2324B) (2425B)简述 ACME 协议的作用与工作原理（5 分）

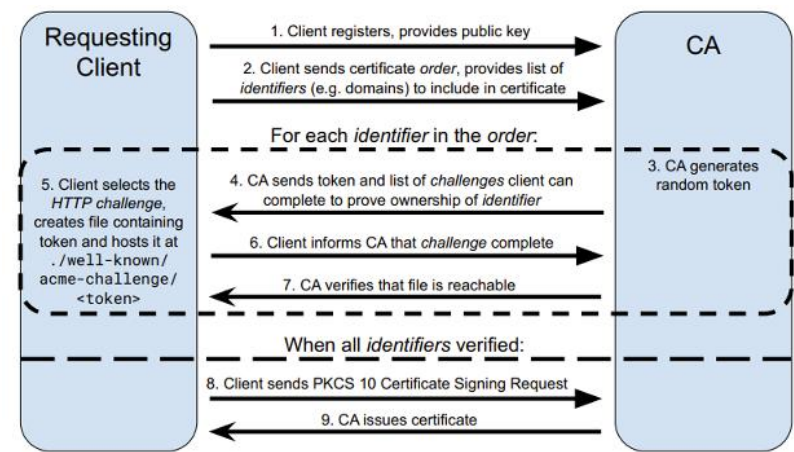


Figure 2: ACME protocol. This diagram illustrates how an ACME client can obtain a certificate without human interaction. In the dashed region, the client proves ownership of the domain using an HTTP-based challenge.

(1) ACME 协议的作用：自动证书管理环境(ACME)协议是一种通信协议，用于自动化证书颁发机构与其用户的 web 服务器之间的交互，允许以非常低的成本自动部署公钥基础设施。

(2) ACME 协议的工作原理：

- ①客户端向 CA 注册账户，并提交公钥
- ②客户端向 CA 发送证书订单，提供需要写入证书的标识符（如域名）
- ③CA 为每个标识符生成随机 token
- ④CA 将 token 及客户端可完成的挑战列表发送给客户端
- ⑤客户端选择一种挑战方式（如 HTTP-01），在服务器指定路径创建包含 token

的验证文件

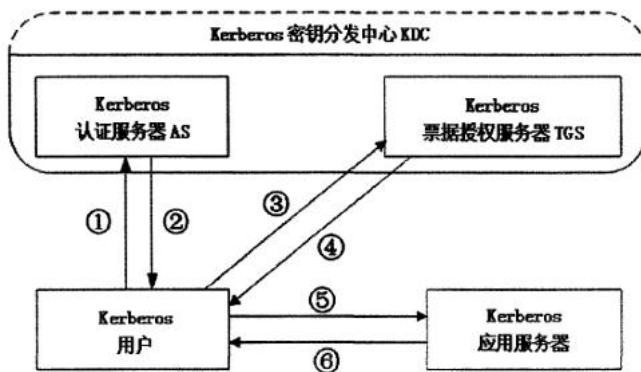
⑥客户端通知 CA 挑战已完成

⑦CA 访问对应资源，验证该文件是否可达，从而确认域名控制权

⑧当所有标识符均验证通过后，客户端发送 PKCS#10 证书签名请求（CSR）

⑨CA 签发证书并返回给客户端

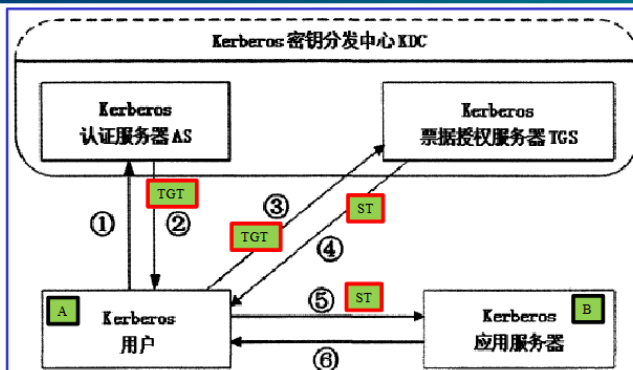
(2425A)解释 Kerberos 协议的工作原理（5 分）



Kerberos 协议

在有效期内，用户A可以继续使用TGT来获得其他服务（C，D，...）的ST，从而完成其他服务（C，D，...）对A的身份认证。

A的password $\rightarrow K_{AS} \rightarrow K_{A-TGS} \rightarrow K_{AB} \rightarrow A$



前提：

- 1) 用户A在AS注册；
- 2) 应用服务器B在TGS注册；

TGT会在某个时间过期，尽管在用户登录期间，它可能会被用户的会话管理器透明地更新。

- 1) 用户把名字A发给AS
- 2) AS根据A从数据库找到对应密钥 K_{AS} ，然后为A和TGS分发会话密钥 K_{A-TGS} ：
Message A: $\{K_{A-TGS}\}_{K_{AS}}$
Message B: **TGT** = $\{A, K_{A-TGS}, IP_A, TVP(ticket\ validity\ period)\}_{K_{TGS}}$
- 3) 用户把**TGT**和**B**发给TGS，并发送 Authenticator = $\{A, TS(timestamp)\}_{K_{A-TGS}}$ 给TGS来认证自己的身份
- 4) TGS为A和B分发会话密钥 K_{AB} ：
Message E: **ST** = $\{A, K_{AB}, IP_A, TVP\}_{K_{BS}}$
Message F: $\{K_{AB}, TS(timestamp)\}_{K_{A-TGS}}$
- 5) 用户A发送**ST**和 Authenticator = $\{A, TS(timestamp)\}_{K_{AB}}$ 给B，B从ST获得**A**和 **K_{AB}** ，然后解密 Authenticator 得到A，两个A如果匹配则**认证通过**。
- 6) B返回 $\{TS(timestamp)\}_{K_{AB}}$ 给A: A解密得到TS，如果时间戳TS正确，就认为B可信的。

有图表的题目

4. 某同学想用简单的示例验证一下 Paillier 同态加密算法, 却惊讶地发现解密出来的明文不正确, 不知道哪里出了错。

具体计算过程如下:

算法	示例: m=2
key generation: 1.随机选择两个大素数p和q; 2.计算$n=pq$, $\lambda=\text{lcm}(p-1,q-1)$, lcm是求两个数的最小公倍数。 3.随机选择基g, $g \in \mathbb{Z}_n^*$, 且满足 $\text{gcd}(L(g^\lambda \bmod n^2), n) = 1$, 其中$L(x)=(x-1)/n$ 4.计算$\mu = (L(g^\lambda \bmod n^2))^{-1} \bmod n$ 那么: 公钥pk=(n, g); 私钥sk=(λ, μ);	密钥生成: 1) 取 $p=3,q=5$, 计算得到 $\lambda=\text{lcm}(2,4)=4$, $n=15$, 2) 选取 $g=11$, 计算出 $u=1$
Encryption: $\text{plaintext } m < n$ select a random $r < n$ $\text{ciphertext } c = g^m \cdot r^n \bmod n^2$ Decryption: $\text{ciphertext } c < n^2$ $\text{plaintext } m = \frac{L(c^\lambda \bmod n^2)}{L(g^\lambda \bmod n^2)} \bmod n$	1) 加密: 取随机数 $r=5$, 计算得到密文 $c=50$; 2) 解密: 对 c 解密得到的明文 $m'=11.6$

请你指出该同学计算过程中哪里出现了错误, 并给出一个正确的计算过程。
(5 分)

该同学在 Paillier 同态加密示例中的错误出现在加密阶段随机数 r 的选取上。在 Paillier 加密算法中, 随机数 r 必须满足 $r \in \mathbb{Z}_n^*$, 即 $\text{gcd}(r, n) = 1$ 。该同学取 $n = 15$, 却选取 $r = 5$, 此时 $\text{gcd}(5, 15) \neq 1$, 违反了算法要求, 导致 Paillier 解密正确性条件不成立, 从而解密得到的明文错误。

正确计算过程如下:

取 $p = 3$, $q = 5$, 则 $n = 15$, $\lambda = \text{lcm}(2,4) = 4$, 选 $g = 11$, 计算得 $\mu = 1$ 。加密明文 $m = 2$ 时, 应选取满足 $\text{gcd}(r, 15) = 1$ 的随机数 (如 $r = 7$), 按 $c = g^m \cdot r^n \bmod n^2$ 得到密文 $c = 73$; 解密时按 $m = \frac{L(c^\lambda \bmod n^2)}{L(g^\lambda \bmod n^2)} \bmod n$ 可正确恢复明文 $m = 2$ 。

1. QQ 浏览器（版本 6.5.0.2170）数据传输的安全问题分析

我们分析了 Android 浏览器版本 6.5.0.2170。
这个版本和更新后的 QQ Browser 服务器实现了以下步骤来加密从客户端到服务器端的 WUP 请求：
1. 首先，客户端为会话生成一个 128 位的 AES 会话密钥，使用伪随机数生成器 (PRNG)，其种子是自 Unix epoch 以来的以毫秒为单位的当前时间。
2. 然后，客户端使用 1024 位的 RSA 公钥对该会话密钥进行加密。公钥的指数是 65537，而 RSA 实现是“教科书式 RSA”（没有应用填充形式）。
3. 客户端使用 AES 会话密钥在 ECB 模式下加密 WUP 请求。
4. 客户端将 RSA 加密的 AES 会话密钥和加密的 WUP 请求发送给服务器。
5. 服务器使用自己的私钥对从客户端接收到的 RSA 加密的 AES 会话密钥进行解密，然后选择明文中最有效率的 128 位作为 AES 会话密钥。
6. 服务器使用通过 RSA 解密获得的 AES 会话密钥解密 WUP 请求。
如果从客户端接收到的 AES 密文正确地解密为有效的 WUP 请求，服务器将使用 AES 会话密钥发送一个 AES 加密的响应(也使用 ECB 模式)。

请分析以上数据传输模式的安全问题，并给出修复问题的方案。（10 分）

（1）存在的安全问题

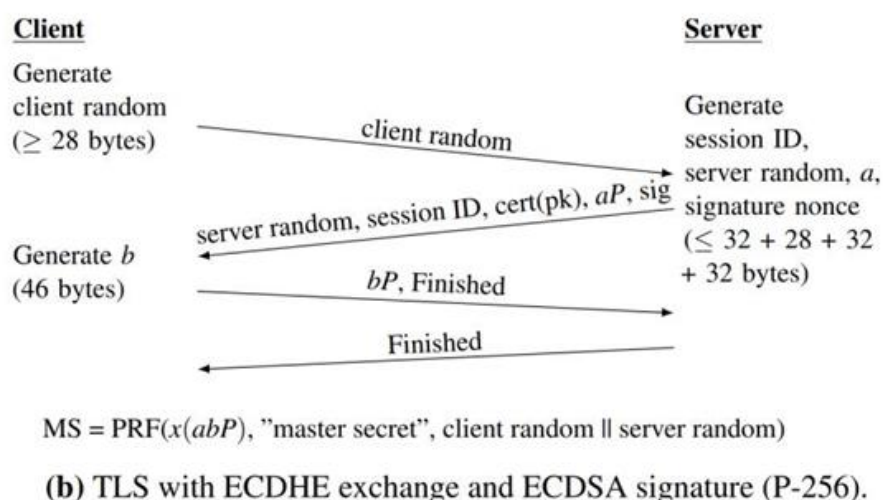
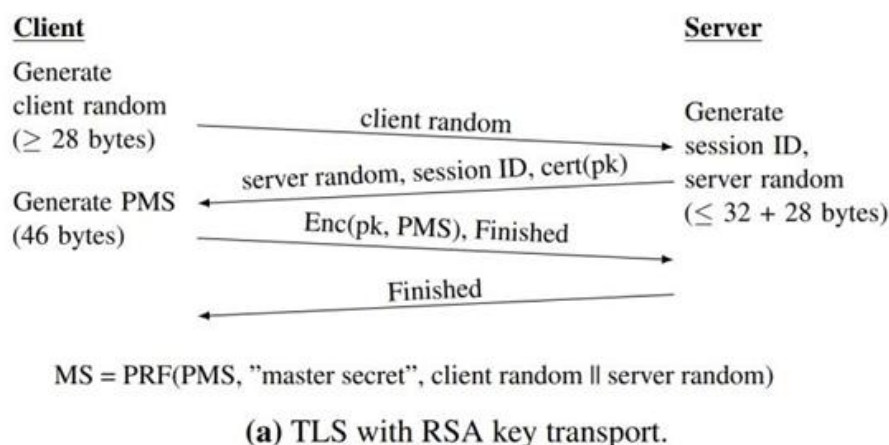
- ①随机数生成不安全：客户端 AES 会话密钥由 PRNG 生成，其种子仅为 Unix epoch 时间（毫秒级），随机性不足。攻击者可通过时间窗口进行穷举预测，从而恢复会话密钥，违反了安全通信对高质量随机数的基本要求。
- ②RSA 使用方式不安全：采用 1024 位 RSA 且为“裸 RSA”（无填充）。1024 位 RSA 已不再满足现代安全要求，且无填充的 RSA 易受到选择密文攻击等密码分析攻击。
- ③对称加密模式不安全：WUP 请求和响应均使用 AES-ECB 模式。ECB 模式不提供随机性，无法隐藏明文结构，容易泄露数据模式和统计特征，安全性较差。
- ④缺乏完整性与认证保护：该方案仅关注加密，未引入消息认证机制（如 HMAC 或 AEAD），无法有效防止数据被篡改和中间人攻击，不满足安全通信对机密性、完整性和认证性的综合要求。

（2）改进方案

- ①使用密码学安全随机数生成器生成会话密钥，避免使用时间作为随机种子。
- ②使用至少 2048 位 RSA 并采用 RSA-OAEP 等安全填充方式，或直接采用 ECDHE 实现前向安全性。
- ③将 AES-ECB 替换为 AES-GCM、AES-CCM 等 AEAD 加密模式，同时提供机密性和完整性保护。
- ④在整体设计上，直接采用标准 TLS 协议进行数据传输，避免自定义加密协议带来的设计和实现漏洞。

(2324A) (2425A)数据安全传输：TLS 握手协议的安全性分析（10 分）

- (1) 解释一下什么是前向安全性？
- (2) 分析图 a 所示的握手协议是否满足前向安全性？
- (3) 分析图 b 所示的握手协议是否满足前向安全性？
- (4) 解释一下针对 DHE 协议的中间人攻击方法。
- (5) 分析一下：图 b 所示的握手协议是如何抵抗中间人攻击的？



(1) 前向安全性是密码学中通信协议的安全属性，是指长期使用的主密钥泄漏不会导致过去的会话密钥泄漏。

通俗来说，前向安全指的是密钥泄漏也不会让之前加密的数据被泄漏，影响的只有当前，对之前的数据无影响。即使有人记录流量并危及服务器以获得其私钥，他们也无法破译该流量。

(2) 图 a 为 TLS with RSA key transport (RSA 密钥传输)：

①预主密钥 (PMS) 由客户端生成；

②PMS 使用服务器的长期 RSA 公钥加密发送；

③如果服务器私钥泄露，攻击者可以解密历史抓包中的 PMS，从而恢复会话密钥。

结论：不满足前向安全性。

(3) 图 b 为 TLS with ECDHE exchange and ECDSA signature：

①客户端和服务端使用临时生成的 ECDHE 密钥对；

②会话密钥由临时密钥协商得到；

③服务器长期私钥仅用于签名，不参与会话密钥生成。

结论：满足前向安全性。

(4) 纯 DHE 协议 不能抵御中间人攻击：

①攻击者分别与客户端、服务器建立 DHE 会话；

②攻击者替换双方的 DH 公钥；

③客户端和服务端实际上分别与攻击者共享密钥。

因此，攻击者可以监听、解密和篡改通信内容。

(5) 图 b 通过 ECDHE + 数字签名 (ECDSA) 抵御中间人攻击：

①服务器对其 DH 参数进行数字签名；

②客户端使用服务器证书验证签名合法性；

③攻击者无法伪造服务器签名，无法替换 DH 参数。

因此，图 b 协议既具备前向安全性，又能抵御中间人攻击。

(2425A)数据匿名化技术：计算 K 匿名和 L 多样性的参数（10 分）

表中是经过匿名化处理的数据集，请问

- （1）该数据集是否满足 K 匿名？如果满足，K 的值是多少？（3 分）
- （2）该数据集是否满足 L 多样性？如果满足，L 的值是多少？（3 分）
- （3）该数据集是否满足 T 相近？解释为什么？（4 分）

表 6-7 概率分布问题

工作	性别	年龄	收入/万美元
*	男性	*	2.05
*	男性	*	5.19
*	男性	*	7.05
作家	女性	30	9.59
舞蹈家	女性	30	1.99
作家	女性	30	8.55
舞蹈家	女性	30	2.00

已知表中：

准标识符（QID）：工作、性别、年龄

敏感属性：收入

- （1）满足 K-匿名。

对每一个相同的 QID 组合，至少有 2 条记录：

QID=(, 男性,) → 3 条记录

QID=(作家, 女性, 30) → 2 条记录

QID=(舞蹈家, 女性, 30) → 2 条记录

等价类中记录数的最小值为 2

- （2）满足 L-多样性。L = 2

在每个等价类中，敏感属性“收入”至少包含 2 个不同取值：

(作家, 女性, 30): 9.59、8.55

(舞蹈家, 女性, 30): 1.99、2.00

- （3）不满足 T-相近性。

- ①虽然满足 K-匿名和 L-多样性，但部分等价类中收入值分布高度集中
- ②例如 (舞蹈家, 女性, 30) 的收入几乎固定在 2 万美元左右
- ③等价类中敏感属性的分布与整体数据集的分布差异较大，攻击者仍可对个体收入进行较准确推断